OWASP Security Audit:

Context: audit checklist of a company, Botium Toys.

Information:

- Small US business with a single physical location serving as main office, storefront, and warehouse
- Online website
- Needs to comply with GDPR and PCI DSS

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Scope: "The scope is defined as the entire security program at Botium Toys. This means all assets need to be assessed alongside internal processes and procedures related to the implementation of controls and compliance best practices."

Goals: "Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture."

CONTROLS CHECKLIST:

Yes:	No:	Control:	Explanation:
	X	Principle of Least Privilege	Employees are freely given excessive privileges, which includes viewing PII/SPII
	X	Disaster Recovery Plans	No disaster recovery plans have been implemented or drafted
	X	Password Policies	Password policies exist, but they do not comply with modern standards
	X	Separation of Duties	Systems do not include strong authorization or role-based mechanisms
X		Firewall	The IT team has a firewall which has appropriate rules
	X	IDS	No IDS system currently existing
	X	Backups	Critical data is not backed up
X		Antivirus Software	Monitored regularly by IT team
	X	Manual monitoring, maintenance, and intervention for legacy systems	While legacy systems are monitored, no regular schedule has been established and intervention procedures are unclear
	X	Encryption	PII/SPII info is not encrypted
	X	Password Management system	There has been no implemented centralized system
X		Locks	The physical location has sufficient locks on both doors and assets
X		CCTV surveillance	The CCTV monitoring system covers the entire building and is secure
X		Fire detection/prevention	Functional and satisfactory

PCI-DSS CHECKLIST:

Yes:	No:	Best Practice:	Explanation:
	X	Only authorized users have access to client's credit card info	Standard employees can access client card info
	X	Credit card info is accepted, processed, transmitted, and stored internally. In a secure environment	Credit card data is not stored in a secured environment
	X	Implement data encryption procedures to better secure credit card transactions touchpoints and data	Sensitive data is not currently being encrypted
	X	Adopt secure password management policies	While password management policies exist, they are not secure

GDPR CHECKLIST:

Yes	No	Best Practice	Explanation:
	X	EU customers' data is kept private/secured	All employees can access customer data
X		There is a plan to notify EU customers within 72 hours if their data is compromised/there is a breach	The IT team has implemented the plan
	X	Ensure that data is properly classified and inventoried	The risk assessment stated that the company had issues with classifying and inventorying digital assets
X		Enforce privacy policies, procedures, and processes to properly document and maintain data	There are process and policies which preform this task sufficiently

SYSTEMS AND ORGANIZATION CONTROLS:

Yes	No	Best Practice	Explanation
	X	User access policies are established	Currently now, average employees can access sensitive financial
	X	Sensitive data (PII/SPII) is confidential/private	Unauthorized employees can easily access PII/SPII. Attackers who compromised an employee device can also access this data
	X	Data integrity ensures that data remains consistent, accurate, and has been validated	The IT team has established availability and integrated controls, but no direct integrity controls
X		Data is available to individuals authorized to access it	Availability has been established.

RECOMMENDATIONS:

While the physical security posture is secure and the company has been working towards security goals, there is still room for improvement.

One of the most critical areas to improve is role-based access and authorization. Implement systems which follow the principle of least privilege strictly, and implement authorization mechanisms which prevents employees from viewing customer data if they do not need to

Customer data also needs to have tighter security mechanisms. Data should be encrypted and only authorized users should be able to access it when they need it. GDPR expects customer data to be handled safely, and the current security posture does not meet European expectations

The company should also consider implementing a reliable and adequate data asset inventory, tracking customers, employees, and products specifically. This will help with the integrity process

Overall, the company needs more security and disaster recovery systems to be installed. Core components like backups, encryption, IDS, and other modern systems all contribute to protecting user data.